Перелік питань ЄДКІ. Тема 1
Законодавча та нормативно-правова база, державні та міжнародні вимоги, практики і стандарти в галузі інформаційної та/або кібербезпеки

1. Якого рівня доступу інформації стосується така інформація: "Бібліографічні й розпізнавальні дані, особисті характеристики, відомості про родинний стан, відомості про майновий або фінансовий стан"?

(вказати варіант правильної відповіді)

А) інформація без обмеження права доступу;

Б) інформація з обмеженим доступом;

В) інформація, поширення якої завдає шкоди інтересам суспільства;

Г) об'єкт інтелектуальної власності;

Д) інша загальнодоступна інформація.

Пояснення:

Згідно з наведеним переліком, "Бібліографічні й розпізнавальні дані, особисті характеристики, відомості про родинний стан, відомості про майновий або фінансовий стан" відноситься до конфіденційної інформації про фізичну особу. Така інформація вважається інформацією з обмеженим доступом і не може вільно поширюватися без згоди особи.

2. У випадку, якщо в АС (що таке АС) планується обробка інформації, порядок обробки і захисту якої регламентується законами України або іншими нормативно-правовими актами, то для обробки такої інформації в цій АС необхідно мати дозвіл:

(вказати варіант правильної відповіді)

А) представника замовника;

Б) відповідного уповноваженого державного органу;

В) міністра;

Г) заступника міністра;

Д) галузевого куратора міністерства.

Пояснення:

Відповідно до законодавства України, якщо в автоматизованій системі (АС) планується обробка інформації, порядок обробки та захисту якої регулюється

законами чи іншими нормативно-правовими актами, то для обробки такої інформації в цій АС необхідно отримати дозвіл від відповідного уповноваженого державного органу. Уповноважені державні органи визначаються залежно від виду інформації, яку планується обробляти. Наприклад, для обробки персональних даних потрібен дозвіл Уповноваженого Верховної Ради України з прав людини, для обробки інформації з обмеженим доступом - відповідних органів державної влади або органів місцевого самоврядування, для обробки інформації в галузі охорони здоров'я - уповноваженого органу виконавчої влади у сфері охорони здоров'я тощо.

3. Скільки класів безпеки описують Критерії оцінки надійних комп'ютерних систем ("Оранжева книга" Міністерства оборони США)?

(вказати варіант правильної відповіді)

А) 5;

Б) 6;

В) 7;

Г) 10;

Д) 4.

Пояснення:

Згідно з "Оранжевою книгою" Міністерства оборони США, відомою як "Критерії оцінки надійних комп'ютерних систем" (Trusted Computer System Evaluation Criteria, TCSEC), було визначено 6 класів безпеки для оцінки надійності комп'ютерних систем. Ці класи, від найнижчого до найвищого рівня безпеки, були:

Клас D - Мінімальна захищеність

Клас C1 - Дискреційний захист

Клас C2 - Контрольована безпека

Клас B1 - Помірна захищеність

Клас B2 - Високий рівень захисту

Клас B3 - Повний мандатний захист

Клас A1 - Перевірена захищеність

1	Питання	Тип: 1	Які події призводять до інциденту інформаційної безпеки згідно стандартів ISO/IEC 27001 та ISO/IEC 27035? C4

Джерело: Аудит та управління інцидентами інформаційної безпеки : навч. посіб. / [Корченко О.Г., Гнатюк С.О., Казмірчук С.В. та ін.]. – К. : Центр навч.-наук. та наук.-пр. видань НА СБ України, 2014. – 190 с. Пункт 4.1., С. 118.

2

2	Питання	Тип: 1	Які основні дії необхідно виконати для досягнення мети управління інцидентами інформаційної безпеки? C5

Джерело: Аудит та управління інцидентами інформаційної безпеки : навч. посіб. / [Корченко О.Г., Гнатюк С.О., Казмірчук С.В. та ін.]. – К. : Центр навч.-наук. та наук.-пр. видань НА СБ України, 2014. – 190 с. Пункт 4.1., С. 117.

3

3	Питання	Тип: 1	Які основні стандарти, рекомендації та найкращі світові практики регламентують управління інцидентами інформаційної безпеки? C1

Джерело: Аудит та управління інцидентами інформаційної безпеки : навч. посіб. / [Корченко О.Г., Гнатюк С.О., Казмірчук С.В. та ін.]. – К. : Центр навч.-наук. та наук.-пр. видань НА СБ України, 2014. – 190 с. Пункт 4.2., С. 125-126.

CS5.1.2 Розслідування кіберінцидентів / кібератак 4

4

4	Питання	Тип: 1	Які основні дії повинні виконуватися на етапі розслідування інциденту інформаційної безпеки? C1

Джерело: Аудит та управління інцидентами інформаційної безпеки : навч. посіб. / [Корченко О.Г., Гнатюк С.О., Казмірчук С.В. та ін.]. – К. : Центр навч.-наук. та наук.-пр. видань НА СБ України, 2014. – 190 с. Пункт 4.3., С. 133.

5

5	Питання	Тип: 1	Якими ресурсами та засобами повинний бути забезпечений персонал при розслідуванні інциденту інформаційної безпеки? C4

Джерело: Аудит та управління інцидентами інформаційної безпеки : навч. посіб. / [Корченко О.Г., Гнатюк С.О., Казмірчук С.В. та ін.]. – К. : Центр навч.-наук. та наук.-пр. видань НА СБ України, 2014. – 190 с. Пункт 5.4., С. 181-182.

CS5.2 Управління ризиками в інформаційній та / або кібербезпеці

CS5.2.1 Ризики інформаційної безпеки

1

6	Питання	Тип: 1	За якою послідовністю дій виконується менеджмент ризиків інформаційної безпеки згідно стандарту ISO/IEC 27005

Джерело: Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.1., С. 135-136.

2

7	Питання	Тип: 1	Що визначає оцінку ризику інформаційної безпеки в стандарті ISO/IEC 27001? C3

Джерело: 1. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.4., С. 213.
2. ДСТУ ISO/IEC 27005:2015 Інформаційні технології. Методи захисту. Менеджмент ризиків інформаційної безпеки (ISO/IEC 27005:2011, IDT).

3

8	Питання	Тип: 1	Які основні міжнародні стандарти регламентують управління ризиками інформаційної безпеки? C1

Джерело: 1. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.1., С. 129-130, 135-139.
2. ДСТУ ISO/IEC 27001:2015 Інформаційні технології. Методи захисту. Системи управління інформаційною безпекою. Вимоги (ISO/IEC 27001:2013; Cor 1:2014, IDT).
3. ДСТУ ISO Guide 73:2013 Керування ризиком. Словник термінів (ISO Guide 73:2009, IDT).

4

9	Питання	Тип: 1	Яка формула щорічно очікуваних збитків ALE (Annual Loss Expectancy) для конкретної загрози є вірною при оцінці ризиків ІБ? C5

Джерело: Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.2., С. 150-151.

CS5.2.2 Аналіз та оцінка ризику. Прийняття ризику. Зменшення ризику. Страхування (перекладання) ризику 5

5

10	Питання	Тип: 1	Які варіанти обробки ризику інформаційної безпеки згідно стандарту ISO/IEC 27005 є вірними? C1

Джерело: Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.5., С. 226-231.
2. ДСТУ ISO/IEC 27005:2015 Інформаційні технології. Методи захисту. Менеджмент ризиків інформаційної безпеки (ISO/IEC 27005:2011, IDT). Пункт 9.1

CS5.2 Управління ризиками в інформаційній та / або кібербезпеці

CS5.2.1 Ризики інформаційної безпеки

1

9	Питання	Тип: 1	Яку методологію процесів менеджменту ризиків ІБ застосовують згідно стандарту ISO/IEC 27005? C4

Джерело: 1. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 1.5., С. 35-36.

CS5.2.2 Аналіз та оцінка ризику. Прийняття ризику. Зменшення ризику. Страхування (перекладання) ризику

2

11	Питання	Тип: 1	З яких заходів складається процес оцінки (оцінювання) ризику інформаційної безпеки згідно стандарту ISO/IEC 27005? C4

Джерело: 1. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.4., С. 214.
2. ДСТУ ISO Guide 73:2013 Керування ризиком. Словник термінів (ISO Guide 73:2009, IDT). Пункт 3.4.1.

3

13	Питання	Тип:1	Що є результатом виконання етапу обробки ризику? C1

Джерело: 1. ДСТУ ISO/IEC 27005:2015 Інформаційні технології. Методи захисту. Менеджмент ризиків інформаційної безпеки (ISO/IEC 27005:2011, IDT). Пункт 3.8.
2. ДСТУ ISO Guide 73:2013 Керування ризиком. Словник термінів (ISO Guide 73:2009, IDT). Пункт 3.8.1.6.
3. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 3.5., С. 227.

CS5.3 Політика інформаційної безпеки

CS5.3.1 Розробка політик ІБ під час забезпечення бізнес-процесів

4

14	Питання	Тип: 1	Яка мета політики інформаційної безпеки забезпечення бізнес-процесів згідно стандарту ISO/IEC 27002? C1

Джерело: 1. ДСТУ ISO/IEC 27002:2015 Інформаційні технології. Методи захисту. Звід практик щодо заходів інформаційної безпеки (ISO/IEC 27002:2013, IDT). Пункт 5.1.
2. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук,

Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 4.1., С. 240.

CS5.3.2 Дотримання політик ІБ під час забезпечення бізнес-процесів

5

15	Питання	Тип: 1	Як часто потрібно переглядати політики інформаційної безпеки забезпечення бізнес-процесів згідно стандарту ISO/IEC 27002? C2

Джерело: 1. ДСТУ ISO/IEC 27002:2015 Інформаційні технології. Методи захисту. Звід практик щодо заходів інформаційної безпеки (ISO/IEC 27002:2013, IDT). Пункт 5.1.2.
2. Менеджмент інформаційної безпеки: навчальний посібник для студентів спеціальності 125 «Кібербезпека» / О.Г. Корченко, М.С. Шелест, С.В. Казмірчук, Ю.М. Ткач, Є.В. Іванчнко. – Ніжін: ФОП Лук'яненко В.В. ТПК «Орхідея», 2019. – 408 с. Пункт 4.1., С. 240.

1

1	Питання	Тип: 1	У чому полягає аудит керування ризиком? А

Джерело: ДСТУ ISO Guide 73:2013

2

2	Питання	Тип: 1	Яких умовах виникає ризик інформаційної безпеки приватної компанії?

Джерело: NIST Special Publication 800-30

3

3	Питання	Тип: 1	Який взаємозв'язок між ризиками інформаційної безпеки і загрозами? А

Джерело: ДСТУ ISO/IEC 27000:2019

4

4	Питання	Тип:1	Що розуміють під загальним оцінюванням ризику? А

Джерело: ДСТУ IEC/ISO 31010:2013

5

5	Питання	Тип:1	Організація відмовилась від ведення інформаційної діяльності. Як, в точки зору ризику компрометації даних та вимог стандартів ISO 31000/31010/27005, називається така дія організації?

Джерело: Відмова від ведення інформаційної діяльності означає відмову володіння інформаційними ресурсами. Немає ресурсів - немає ризиків для них. За визначенням це відповідає уникненню ризику. Уникнення ризику - це не виконання жодної діяльності, яка може нести ризик.

6

6	Питання	Тип:1	Що таке політика інформаційної безпеки?

7

7	Питання	Тип:1	Який взаємозв'язок між ризиками інформаційної безпеки, загрозами і вразливостями інформаційних активів?А

Джерело: ДСТУ ISO/EC 27000:2019

8

8	Питання	Тип:1	На якому етапі процесу управління ризиками інформаційної безпеки (згідно з ДСТУ ISO/IEC 27005:2019) визначаються базові критерії оцінювання ризиків?

Джерело: ДСТУ ISO/IEC 27005:2019.

9

9	Питання	Тип:1	На якому етапі процесу управління ризиками інформаційної безпеки (згідно з ДСТУ ISO/IEC 27005:2019) приймається рішення щодо прийнятності ризиків? В

Джерело: ДСТУ ISO/IEC 27005:2019.

10

10	Питання	Тип:1	На якому рівні мають бути конкретизовані загальні правила розмежування доступу при розробці політики безпеки інформації в АС згідно НД ТЗІ 1.4-001-2000? В

Джерело: НД ТЗІ 1.4-001-2000.

1) Що означає термін "інформація" в контексті технічного захисту інформації?

a) Відомості про суб'єкти, об'єкти, явища та процеси

b) Відомості з обмеженим доступом

c) Відомості, право доступу до якої обмежено встановленими правовими нормами

d) Конфіденційні відомості

Правильна відповідь: a) Відомості про суб'єкти, об'єкти, явища та процеси

2) Яке визначення терміна "таємна інформація" є вірним?

a) Інформація, право доступу до якої обмежено встановленими правовими нормами

b) Інформація з обмеженим доступом, яка містить відомості, що становлять державну або іншу передбачену законом таємницю

c) Інформація, якою володіють, користуються чи розпоряджаються окремі фізичні чи юридичні особи або держава

d) Формалізований опис методів та засобів здійснення захисту інформації

Правильна відповідь: b) Інформація з обмеженим доступом, яка містить відомості, що становлять державну або іншу передбачену законом таємницю

3) Що означає термін "витік інформації"?

a) Вплив на технічні засоби, що призводить до здійснення загрози для інформації

b) Розповсюдження спотвореної інформації

c) Унеможливлення санкціонованого доступу до інформації

d) Неконтрольоване поширення інформації, яке призводить до її несанкціонованого одержання

Правильна відповідь: d) Неконтрольоване поширення інформації, яке призводить до її несанкціонованого одержання

4) Як визначається "спеціальний вплив" в контексті технічного захисту інформації?

a) Неконтрольоване поширення інформації, яке призводить до її несанкціонованого одержання

b) Формалізований опис методів та засобів здійснення впливу на інформацію

c) Вплив на технічні засоби, що призводить до здійснення загрози для інформації

d) Несанкціоноване здобування інформації за допомогою технічних засобів та її аналіз

Правильна відповідь: c) Вплив на технічні засоби, що призводить до здійснення загрози для інформації

5) Що означає термін "носій інформації (ТЗІ)"?

a) Матеріальний об'єкт, що містить інформацію, яка підлягає захисту від загроз.

b) Фізичні поля та (чи) хімічні речовини, що містять інформацію з обмеженим доступом.

c) Сукупність носіїв інформації, середовища поширення та засобів технічної розвідки.

Правильна відповідь: a) Матеріальний об'єкт, що містить інформацію, яка підлягає захисту від загроз.

6) Що означає термін "інформативний сигнал (ТЗІ)"?

a) Матеріальний об'єкт, що містить інформацію, яка підлягає захисту від загроз.

b) Фізичні поля та (чи) хімічні речовини, що містять інформацію з обмеженим доступом.

c) Сукупність носіїв інформації, середовища поширення та засобів технічної розвідки.

Правильна відповідь: b) Фізичні поля та (чи) хімічні речовини, що містять інформацію з обмеженим доступом.

7) Що означає термін "зона безпеки інформації"?

a) Простір, в межах якого інформація убезпечена.

b) Сукупність організаційних структур, нормативно-правових документів та матеріально-технічної бази.

c) Сукупність вимог, у тому числі нормованих, що визначаються режимом доступу до інформації та загрозами безпеці.

Правильна відповідь: a) Простір, в межах якого інформація убезпечена.

8) З якою послідовністю виконується технічний інформації:

a) реалізація плану захисту інформації;

b) контроль фукціювання та керування системою захисту інформації;

c) визначення й аналіз загроз;

d) розроблення системи захисту інформації.

Правильна відповідь: 1) c; 2) d; 3) a; 4) b;

Такі тести краще не робити бо їх в тг ніяк реалізувати)))

9) Нормативні документи з ТЗІ поділяються на(виберіть декілька правильних відповідей):

a) Інструкції з технічного захисту інформації.

b) Довідники з технічного аудиту інформаційних систем.

c) Нормативні акти міжвідомчого значення, що реєструються у Міністерстві юстиції України.

d) Нормативні документи міжвідомчого значення технічного характеру, що реєструються органом, уповноваженим Кабінетом Міністрів України.

e) Стандарти з організації інформаційної безпеки.

f) Нормативні документи із стандартизації у галузі ТЗІ.

g) Нормативні документи щодо криптографічного захисту даних.

h) Нормативні документи відомчого значення органів державної влади та органів місцевого самоврядування.

i) Державні стандарти та прирівняні до них нормативні документи.

Правильні відповіді: c), d), f), h), i)

10) Що таке комп'ютерна система?

a) Сукупність організаційно-технічних засобів.

b) Сукупність програмно-апаратних засобів, призначених для обробки інформації.

c) Організаційно-технічна система, що реалізує інформаційну технологію.

Правильна відповідь: b) Сукупність програмно-апаратних засобів, призначених для обробки інформації.

11) Що таке загроза?

a) Обставини або події, що можуть бути причиною порушення політики безпеки інформації.

b) Стан інформації, в якому забезпечується збереження властивостей інформації.

c) Діяльність, спрямована на забезпечення безпеки оброблюваної в АС інформації та АС в цілому.

Правильна відповідь: a) Обставини або події, що можуть бути причиною порушення політики безпеки інформації.

12) Що таке авторизація?

a) Надання повноважень.

b) Одержання користувачем або процесом інформації, що міститься в об’єкті.

c) Сукупність заходів з визначення повноважень і прав доступу.

Правильна відповідь: a) Надання повноважень.

13 Що таке модифікація?

a) Зміна користувачем або процесом інформації, що міститься в об’єкті.

b) Передавання інформації від одного до іншого об’єкта КС.

c) Вид взаємодії двох об’єктів КС.

Правильна відповідь: a) Зміна користувачем або процесом інформації, що міститься в об’єкті.

14) Що таке конфіденційність інформації?

a) Технологія передачі інформації через відкриті мережі

b) Процес захисту інформації від проникнення комп'ютерних вірусів.

c) Властивість інформації, яка полягає в тому, що інформація не може бути отримана неавторизованим користувачем і/або процесом.

d) Ступінь доступності інформації для користувачів.

Правильна відповідь: c) Властивість інформації, яка полягає в тому, що інформація не може бути отримана неавторизованим користувачем і/або процесом.

15) Що таке критична інформація?

a) Властивість інформації, що описує її ступінь конфіденційності.

b) Інформація, яка має бути доступна для всіх користувачів системи.

c) Тип інформації, яка найчастіше піддається модифікації.

d) Інформація, яка потребує посиленого захисту через свою важливість.

Правильна відповідь: a) Інформація, яка потребує посиленого захисту через свою важливість.

16) Що таке доступність в контексті інформаційної безпеки?

a) Властивість інформації, яка описує її ступінь захищеності від несанкціонованого доступу.

b) Ступінь доступності інформації для користувачів у визначених часових рамках.

c) Технологія, яка дозволяє зберігати інформацію на зовнішніх носіях.

d) Процес захисту інформації від комп'ютерних вірусів.

Правильна відповідь: b) Ступінь доступності інформації для користувачів у визначених часових рамках.

1. У відповідності з вимогами якого стандарту записується значення полів підрівня LLC? А: 802.1 Б:802.2 В: 802.3

2. Яка організація створена для розробки стандартів локальних мереж?

А: OSI Б: IEEE В: ECMA Г: EIA

3. Які стандарти описують побудову мережі Ethernet?

А: IEEE 802.1 Б: IEEE 802.2 В: IEEE 802.3 Г: IEEE 802.11

4. Комплекс комунікаційних елементів, які забезпечують з'єднання вузлів в локальну мережу згідно з існуючими стандартами, це:

А: СКС Б: IEEE В: АПД

5. Значення полів кадру 802.3/LLC відповідає з вимогами стандарту : А: 802.2 і 802.3 Б: 802.2 В: 802.3

6. Яка специфікація стандарту 802.3ab використовує чотири скручених пари UTP категорії 5: А: 100Base-T4 Б: 100Base-TX Г: 1000Base-T

7. Для побудови магістралей локальних мереж стандарти 802.3z рекомендують використовувати технологію: А: Ethernet Б: Fast Ethernet В: Gigabit Ethernet

8. Який з наведених стандартів носить назву "Wi- Maxi":

А: IEEE 802.11a Б: IEEE 802.11b В: IEEE 802.11g Г: IEEE 802.16

9. Який стандарт описує віддалений доступ з допомогою технології «Wi-Max»? А: IEEE 802.11 g Б: IEEE 802.15 В: IEEE 802.11b Г: IEEE 802.16

10. Час передачі кадру мінімальної довжини в стандарті Ethernet-10Base-5?

A. 67,2 мкс.

B. 57,6 мкс.

C. 46 мкс.

D. 128 мкс.

1. Зі скількох дій, згідно стандарту ISO/IEC TR 13335-2:2003, складається загальний огляд керування ризиком організації?

а) десяти;

б) шести;

в) трьох;

г) однієї;

д) чотирьох

Р 1 (правильна відповідь в)

2. Яку кількість, рекомендованих стандартом, резервних копій для особливо важливої інформації необхідно зберігати:

а) одну;

б) дві;

в) три;

г) чотири;

д) правильна відповідь відсутня

Р1 (правильна відповідь б)

3. Які з перелічених нижче засобів контролю відносяться до ключових згідно стандарту ISO/IEC 17799:2005:

а) настановчі рекомендації щодо розподілу IP-адрес організації;

б) планування безперервної роботи організації;

в) децентралізація інформаційної системи організації;

г) використання списків доступу для захисту сегментів мережі організації

д) правильна відповідь відсутня

Р1 (правильна відповідь в)

4. Які з перелічених нижче засобів контролю відносяться до ключових згідно стандарту ISO/IEC 17799:2005:

а) впровадження засобів структуризації мережі на фізичному рівні;

б) засоби структуризації мережі на канальному рівні;

в) засоби захисту від вірусних програм;

г) комутатори Ethernet 3-го рівня;

д) правильна відповідь відсутня

Р1 (правильна відповідь а)

5. Основна мета, згідно стандарту, процедур контролю і аналізу інцидентів організації:

а) підвищення загального рівня захищеності організації;

б) використання зібраних даних для покращення ІР-структуризації

інформаційної системи;

в) визначення порядку взаємодії між потерпілими від інциденту і учасниками

процесу відновлення;

г) запобігання збоям в інформаційних системах;

д) правильна відповідь відсутня

Р 1 (правильна відповідь г)

6. До резервних копій, згідно стандарту, повинен бути застосований адекватний ряд:

а) процедурних заходів захисту;

б) розподільчих заходів захисту;

в) структурних заходів захисту;

г) фізичних і організаційних заходів захисту;

д) правильна відповідь відсутня

Р1 (правильна відповідь а)

7. Відповідно до стандарту, при прийомі на роботу нових працівників необхідно, щоб вони ознайомилися і підписали:

а) угоду про конфіденційність;

б) угоду про нерозголошення державної таємниці;

в) письмове зобов’язання щодо проведення аудиту інформаційної системи;

г) угоду про адміністративну відповідальність;

д) правильна відповідь відсутня

Р1 (правильна відповідь д)

8. До програмних ресурсів згідно стандарту належать:

а) монітор;

б) системний блок;

в) джерела живлення;

г) автовідповідач;

д) правильна відповідь відсутня

Р 1 (правильна відповідь г)

1. До фізичних ресурсів згідно стандарту належать:

а) інструкції з експлуатації;

б) СУБД;

в) прикладне програмне забезпечення;

г) обчислювальне обладнання;

д) правильна відповідь відсутня

Р 1 (правильна відповідь г)

1. DVD-RW диск, який містить конфіденційні дані працівників організації, при виведенні його з експлуатації рекомендується стандартом:

а) повністю очистити засобами Windows;

б) повністю очистити засобами LINUX;

в) багаторазово перезаписати;

г) фізично знищити;

д) правильна відповідь відсутня

Р 1 (правильна відповідь г)

2. До організаційних заходів щодо забезпечення безпеки згідно стандарту належить:

а) захист серверів організації від несанкціонованого доступу;

б) створення облікових даних користувачів організації;

в) нівелювання наслідків порушення політики безпеки;

г) створення профільних форумів по інформаційній безпеці і управління ними;

д) правильна відповідь відсутня

Р 1 (правильна відповідь в)

3. До якого ключового механізму стандарту з управління інформаційною безпекою відноситься безпечне знищення відпрацьованого устаткування?

а) організаційні заходи щодо забезпечення безпеки;

б) безпека персоналу;

в) фізична безпека;

г) управління доступом до ресурсів ІС;

д) правильна відповідь відсутня

Р 1 (правильна відповідь г)

1. Застосування (згідно рекомендацій стандарту) вибраних засобів захисту для інформаційної системи організації повинне приводити до:

а) повного нівелювання ризиків;

б) максимізації зручності використання;

в) максимізації співвідношення ціна/якість для мережі організації;

г) пониження ризиків до допустимого рівня;

д) правильна відповідь відсутня

Р 1 (правильна відповідь б)

2. Яка, згідно стандарту, форма запису паролю в сучасних мережевих операційних системах не є допустимою:

а) "Startap_4";

б) "АК_74";

в) "Stalker+1";

г) "Airbus=243";

д) правильна відповідь відсутня:

Р 2 (правильна відповідь б)

1. Життєвий цикл системи інформаційних технологій, згідно стандарту ISO/IEC TR 13335-2:2003, поділяється на:

а) дві базові стадії;

б) три базові стадії;

в) на базові стадії, пов’язані з впровадженням організаційно-правових заходів

щодо забезпечення безпеки інформаційних технологій;

г) чотири базові стадії;

д) правильна відповідь відсутня

Р 2 (правильна відповідь в)

2. Вказати правильний варіант відповіді.

Згідно стандарту щодо управління інформаційною безпекою, «мозковий штурм» це:

а) тестування систем і сервісних програм постачальників у разі аварій;

б) тестування технічних заходів щодо відновлення інформаційної системи у відведений проміжок часу;

в) обговорення заходів щодо відновлення бізнесу в разі аварій;

г) тестування технічних засобів щодо відновлення в альтернативному місці;

д) правильна відповідь відсутня

Р 2 (правильна відповідь г)

1. Задача забезпечення інформаційної безпеки, згідно стандарту, повинна вирішуватися:

а) на рівні керівництва;

б) на рівні керівництва та системних адміністраторів;

в) на рівні мережевих та системних адміністраторів;

г) на всіх рівнях в організації – від вищого керівництва до рядового працівника;

д) правильна відповідь відсутня

Р 2 (правильна відповідь в)

3. Розподіл відповідальності за забезпечення інформаційної безпеки організації, згідно стандарту, вимагає щоб:

а) розмежування відповідальності було визначено між собою усіма

працівниками організації;

б) розмежування відповідальності було визначено старшим адміністратором

мережі;

в) розмежування відповідальності було закріплено документально;

г) розмежування відповідальності стосувалося лише тих працівників, які

безпосередньо пов’язані із захистом інформації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь а)

4. Відповідно до стандарту, необхідно включати задачу забезпечення безпеки організації в посадові обов'язки:

а) усіх працівників;

б) керівника та менеджерів організації;

в) керівників відділів, менеджерів та системних адміністраторів організації;

г) осіб, безпосередньо відповідальних за забезпечення безпеки організації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь б)

5. До обов’язків якої посадової особи організації, згідно стандарту, відноситься питання щодо підтримки корпоративних методик захисту інформаційних технологій і директив:

а) кваліфікованого працівника з інформаційних технологій;

б) контролера безпеки інформаційних технологій;

в) головного адміністратора корпорації;

г) фахового менеджера організації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь в)

6. Найважливішою частиною (згідно стандарту) процесу керування безпекою інформаційних технологій є:

а) розроблення корпоративних засобів захисту інформаційних ресурсів;

б) створення плану стосовно підтримки і керування інформаційним трафіком;

в) оцінка ризиків і визначення способу, яким їх можна привести до допустимого рівня;

г) оцінка ризиків втрати конфіденційності публічних даних;

д) правильна відповідь відсутня

Р 2 (правильна відповідь б)

8. До якого ключового механізму стандарту з управління інформаційною безпекою відноситься вимога укладання угод про дотримання режиму інформаційної безпеки з усіма працівниками?

а) організаційні заходи щодо забезпечення безпеки;

б) безпека персоналу;

в) фізична безпека;

г) управління доступом до ресурсів ІС;

д) правильна відповідь відсутня

Р 2 (правильна відповідь г)

9. Координація питань, пов'язаних з інформаційною безпекою, згідно стандарту, належить до:

а) фізичних заходів щодо забезпечення безпеки;

б) заходів щодо безпеки персоналу;

в) виключно до компетенції системного адміністратора;

г) організаційних заходів щодо забезпечення безпеки;

д) правильна відповідь відсутня

Р 2 (правильна відповідь а)

10. Який основний захід, згідно стандарту, повинен бути ужитий щодо захисту інформаційної системи від вірусних програм?

а) обов'язковість вживання лише ліцензійного програмного забезпечення;

б) застосування процедур автентифікації;

в) застосування процедур шифрування повідомлень;

г) застосування процедури цифрового підпису на прикладне програмне забезпечення;

д) проведення модернізації операційних систем

Р 2 (правильна відповідь в)

3. Розподіл відповідальності за забезпечення інформаційної безпеки організації, згідно стандарту, вимагає щоб:

а) розмежування відповідальності було визначено між собою усіма працівниками організації;

б) розмежування відповідальності було визначено старшим адміністратором мережі;

в) розмежування відповідальності було закріплено документально;

г) розмежування відповідальності стосувалося лише тих працівників, які безпосередньо пов’язані із захистом інформації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь а)

4. Відповідно до стандарту, необхідно включати задачу забезпечення безпеки організації в посадові обов'язки:

а) усіх працівників;

б) керівника та менеджерів організації;

в) керівників відділів, менеджерів та системних адміністраторів організації;

г) осіб, безпосередньо відповідальних за забезпечення безпеки організації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь б)

5. До обов’язків якої посадової особи організації, згідно стандарту, відноситься питання щодо підтримки корпоративних методик захисту інформаційних технологій і директив:

а) кваліфікованого працівника з інформаційних технологій;

б) контролера безпеки інформаційних технологій;

в) головного адміністратора корпорації;

г) фахового менеджера організації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь в)

6. Найважливішою частиною (згідно стандарту) процесу керування безпекою інформаційних технологій є:

а) розроблення корпоративних засобів захисту інформаційних ресурсів;

б) створення плану стосовно підтримки і керування інформаційним трафіком;

в) оцінка ризиків і визначення способу, яким їх можна привести до допустимого рівня;

г) оцінка ризиків втрати конфіденційності публічних даних;

д) правильна відповідь відсутня

Р 2 (правильна відповідь г)

9. Координація питань, пов'язаних з інформаційною безпекою, згідно стандарту, належить до:

а) фізичних заходів щодо забезпечення безпеки;

б) заходів щодо безпеки персоналу;

в) виключно до компетенції системного адміністратора;

г) організаційних заходів щодо забезпечення безпеки;

д) правильна відповідь відсутня

Р 2 (правильна відповідь а)

10. Який основний захід, згідно стандарту, повинен бути ужитий щодо захисту інформаційної системи від вірусних програм?

а) обов'язковість вживання лише ліцензійного програмного забезпечення;

б) застосування процедур автентифікації;

в) застосування процедур шифрування повідомлень;

г) застосування процедури цифрового підпису на прикладне програмне забезпечення;

д) проведення модернізації операційних систем

Р 2 (правильна відповідь б)

5. До обов’язків якої посадової особи організації, згідно стандарту, відноситься питання щодо підтримки корпоративних методик захисту інформаційних технологій і директив:

а) кваліфікованого працівника з інформаційних технологій;

б) контролера безпеки інформаційних технологій;

в) головного адміністратора корпорації;

г) фахового менеджера організації;

д) правильна відповідь відсутня

Р 2 (правильна відповідь в)

6. Найважливішою частиною (згідно стандарту) процесу керування безпекою інформаційних технологій є:

а) розроблення корпоративних засобів захисту інформаційних ресурсів;

б) створення плану стосовно підтримки і керування інформаційним трафіком;

в) оцінка ризиків і визначення способу, яким їх можна привести до допустимого рівня;

г) оцінка ризиків втрати конфіденційності публічних даних;

д) правильна відповідь відсутня

Р 2 (правильна відповідь в)

2. До яких процедур рекомендує стандарт переходити після завершення атестації інформаційної системи ?

а) до процедур верифікації;

б) до процедур вибору засобів технічного захисту;

в) до процедур доопрацювання;

г) до процедур вибору систем захисту;

д) правильна відповідь відсутня

Р 2 (правильна відповідь б)

5. Згідно вимог стандарту, доступ користувачам до ресурсів інформаційної системи повинен надаватися:

а) лише після успішного проходження ними процесу ідентифікації;

б) лише після успішного проходження ними процесу ідентифікації і автентифікації;

в) будь-який користувач завжди повинен мати безперешкодний доступ до ресурсів інформаційної системи;

г) лише після успішного застосування ними цифрового підпису;

д) правильна відповідь відсутня

Р 2 (правильна відповідь а)

6. До інформаційних ресурсів згідно стандарту належать:

а) системна документація;

б) системне апаратне забезпечення;

в) комутатори Ethernet;

г) модеми;

д) правильна відповідь відсутня

Р 2 (правильна відповідь г)

1. Середовищу зі середнім рівнем довіри, згідно стандарту, відповідатиме мережа:

а) мережа з невідомими користувачами;

б) мережа з приватними мережними з’єднаннями користувачами;

в) мережа із загальнодоступними мережними з’єднаннями користувачами;

г) мережа з відомою групою користувачів в обмеженій діловій спільноті;

д) правильна відповідь відсутня

Р 2 (правильна відповідь а)

3. Середовищу з низьким рівнем довіри, згідно стандарту, відповідатиме мережа:

а) мережа з невідомими користувачами;

б) мережа з відомою групою користувачів у спільній діловій спільноті;

в) мережа із загальнодоступними мережними з’єднаннями користувачами;

г) мережа з відомою групою користувачів в обмеженій діловій спільноті;

д) правильна відповідь відсутня

Р 2 (правильна відповідь г)

6. До резервних копій згідно стандарту повинен бути застосований адекватний ряд:

а) фізичних заходів захисту;

б) нормативно-правових заходів захисту;

в) програмних заходів захисту;

г) фізичних і організаційних заходів захисту;

д) організаційно-розпорядчих заходів захисту

Р 2 (правильна відповідь г)

2. Що рекомендує стандарт при наданні користувачу прав в інформаційній системі?

а) рекомендується надавати доступ користувачам не тільки до операційної системи в цілому, але і, при необхідності, до окремих додатків і утиліт;

б) рекомендується згрупувати усіх користувачів в один домен, якому надається один привілей доступу як до операційної системи в цілому, так і до окремих додатків і утиліт.

в) рекомендується надавати доступ користувачам до об’єктів інформаційної системи в цілому;

г) рекомендує наділяти всіх користувачів мінімальними привілеями до об’єктів інформаційної системи, які необхідні для виконання ними поставлених завдань.

д) правильна відповідь відсутня.